

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

Cybersecurity DR — Versión 2.0 | Julio 2026

1. OBJETIVO Y ALCANCE

Esta política establece los principios, responsabilidades y controles de seguridad aplicables a todos los activos de información de **Cybersecurity DR**, incluyendo datos de clientes, infraestructura técnica, documentación interna y sistemas de terceros. Su objetivo es garantizar la confidencialidad, integridad y disponibilidad (CID) de la información.

Alcance: Aplica a todo el personal, contratistas, proveedores y terceros que accedan a los activos de información de Cybersecurity DR.

2. CLASIFICACIÓN DE LA INFORMACIÓN

La información se clasifica en cuatro niveles:

Nivel	Descripción	Ejemplos	Manejo
Público	Información destinada al público general.	Sitio web, folletos comerciales.	Sin restricciones.
Interno	Uso exclusivo dentro de la organización.	Políticas internas, organigramas.	Acceso autenticado.
Confidencial	Divulgación limitada a roles específicos.	Datos de clientes, contratos, auditorías.	Cifrado en tránsito y reposo.
Restringido	Información crítica; divulgación mínima.	Claves criptográficas, credenciales de infraestructura.	Acceso MFA obligatorio, registro de auditoría.

Procedimiento de clasificación: Todo documento o activo debe etiquetarse al momento de su creación. El Comité de Seguridad revisa la clasificación trimestralmente.

3. CONTROLES DE ACCESO

- Principio del menor privilegio:** Los usuarios reciben únicamente los permisos estrictamente necesarios para su rol.
- Autenticación multifactor (MFA):** Obligatoria para acceso a sistemas críticos, repositorios de código y consolas de nube.
- Gestión de identidades:** Centralizada mediante Azure AD / Okta. Las cuentas inactivas por más de 30 días son deshabilitadas automáticamente.
- Revisión de accesos:** Mensual para privilegios administrativos; semestral para accesos estándar.

4. SEGURIDAD DE LA INFRAESTRUCTURA

- **Perímetro:** Firewall de próxima generación (NGFW) con inspección profunda de paquetes (DPI).
 - **Segmentación:** La red se divide en VLANs: DMZ, Servidores de Aplicaciones, Bases de Datos, Desarrollo y Administración.
 - **Endurecimiento:** Todos los servidores siguen la guía CIS Benchmarks. No se permite el acceso SSH directo desde Internet; se utiliza un bastión host (Jump Server) con autenticación por certificado.
 - **Parches:** Política de ventana de parches de 72 horas para vulnerabilidades críticas (CVSS ≥ 9.0) y 14 días para vulnerabilidades altas.
-

5. CIFRADO Y PROTECCIÓN DE DATOS

- **En tránsito:** TLS 1.3 como mínimo para todas las comunicaciones.
 - **En reposo:** AES-256 para bases de datos, discos de servidor y backups.
 - **Gestión de claves:** AWS KMS / HashiCorp Vault con rotación automática cada 90 días.
 - **Datos personales:** Cumplimiento con GDPR, LGPD y normativas locales de protección de datos.
-

6. SEGURIDAD EN EL DESARROLLO (DevSecOps)

- **Análisis estático (SAST):** Integrado en CI/CD; umbral máximo de vulnerabilidades críticas = 0.
 - **Análisis dinámico (DAST):** Ejecutado semanalmente en ambientes de staging.
 - **Dependencias:** Escaneo automático con OWASP Dependency-Check y Snyk.
 - **Contenedores:** Imágenes Docker escaneadas antes del push al registro. No se permiten imágenes con CVE críticos sin excepción documentada.
-

7. CONCIENTIZACIÓN Y CAPACITACIÓN

- **Onboarding:** Todo nuevo colaborador recibe capacitación en seguridad de 8 horas antes de recibir accesos.
 - **Phishing simulado:** Campañas mensuales. Usuarios que fallen 2 veces consecutivas reciben capacitación reforzada.
 - **Certificaciones requeridas para el equipo técnico:** CISSP, CEH, CompTIA Security+, GIAC o equivalentes.
-

8. INCUMPLIMIENTO Y SANCIONES

El incumplimiento de esta política puede resultar en medidas disciplinarias, incluyendo la terminación de contrato y acciones legales según la gravedad de la violación.

Aprobado por: Director de Seguridad de la Información

Fecha de vigencia: 01/07/2026

Próxima revisión: 01/01/2027